

Contents

1	FR15: セキュリティ	1
1.1	0. 文書情報	1
1.2	1. 機能概要	1
1.3	2. 収録 FR-NNN 一覧	1
1.4	3. 補足説明・統合参照	2
1.5	4. 関連設計	2
1.6	5. 未確定事項・確認事項	2

1 FR15: セキュリティ

1.1 0. 文書情報

項目	内容
文書名	FR15: セキュリティ
機能グループ	セキュリティ
対象システム	FAQ AI ウィジェット SaaS / メインシステム
作成日	2026-05-17
版数	v1.0
ステータス	承認済

1.2 1. 機能概要

項目	内容
概要	通信暗号化(HTTPS)、機密データの暗号化保存、API・ウィジェットへのレート制限、ウィジェット埋め込み元ドメイン検証、再入室トークン、最小権限、Bot 対策、不審リクエスト検知、ユーザー管理操作の監査ログ、プロジェクト単位の IP 許可リスト(ウィジェットアクセス制限)、API キーローテーション・有効期限、不正利用検知連携を扱う
利用場面	日常的な認証認可運用、ウィジェット不正利用検知、API キー管理、プロジェクト別ウィジェット IP 制限導入、不正利用発生時の自動ブロック
優先度	Must

1.3 2. 収録 FR-NNN 一覧

ID	要件	優先度
FR-170	通信は暗号化されること(HTTPS)	P0
FR-171	保存データのうち機密度の高い項目(パスワード、トークン、課金情報等)は暗号化または安全なハッシュで保存されること	P0
FR-172	API・ウィジェットに対してレート制限ができること	P0
FR-173	ウィジェットの埋め込み元ドメインを検証できること(許可ドメイン以外からの読み込み拒否)	P0
FR-174	個別チャットへの再入室はメール経由のトークンや有効期限付きリンクで行えること	P0
FR-175	管理者の操作ログを監査用に保持できること	P0
FR-176	アクセス制御は最小権限の原則に従うこと(オーナー境界によるデータ分離、ユーザー種別別認可)	P0
FR-177	Bot 対策(CAPTCHA 等)を必要に応じて実施できること	P1
FR-178	不審なリクエスト(大量アクセス、未許可ドメイン等)を検知・記録できること	P0
FR-178a	メンバー招待、招待再送、メンバー権限フラグ変更、メンバー削除のいずれの操作も監査ログに記録できること。記録項目は操作者・対象メンバー・変更前後の権限セット差分(該当時)・対応理由(任意)・実行時刻を含むこと	P0
FR-179	FAQ ウィジェット(エンドユーザーアクセス)に対するプロジェクト単位の IP 許可リスト機能を提供すること(オプトイン、初期設定空=制限なし)。設定権限はオーナーおよび project:manage フラグ保持メンバー(該当プロジェクト割当あり)。管理画面側 API は本 IP 許可リストの評価対象外	P1

ID	要件	優先度
FR-193	API キー（公開キー）のローテーション機能を管理者操作で提供すること。新キー発行と同時に旧キーは 30 日の猶予期間 付きで失効予告状態となり、猶予中は両キーで認証を許可する。猶予中のアクセスログは両キーで記録（どちらの利用率が高いかを管理者が確認可能）。猶予期間経過後は旧キーを完全失効とすること	P0
FR-194	API キー（ウィジェット公開キー含む）には有効期限を設定可能とすること（最長 1 年、無期限不可）。管理者は 7 日 / 30 日 / 90 日 / 180 日 / 1 年 から有効期限を選択できること。デフォルトは 1 年とする。キー形式、失効方式、ローテーション猶予期間は基本設計を正本とする（FR-193 / NFR-322 と整合）	P0
FR-195	不正利用検知（大量送信・Bot 疑い・規約違反）について、(a) 自動検知はメインシステム側で行うこと、(b) 判定ルール・しきい値は顧客管理システムから契約別の上書き可能とすること、(c) 自動ブロックはメインシステム側で実行すること、(d) 自動ブロック発火時は管理者ユーザーへ即時通知し、申し立て窓口を案内すること、(e) 運営者の手動判断による緊急停止は顧客管理システム FR-224 から実行されること。連携方式と通知種別は基本設計を正本とする	P1

1.4 3. 補足説明・統合参照

（該当なし。セキュリティ非機能要件は NFR-301～332 を、 管理は NFR-320～324 を参照）

1.5 4. 関連設計

種別	参照先
画面設計	../02_ 基本設計/01_ 画面設計.md
API 設計	../02_ 基本設計/02_ API 設計.md
テーブル設計	../02_ 基本設計/03_ テーブル設計.md
権限設計	../02_ 基本設計/04_ 権限設計.md
エラー設計	../02_ 基本設計/05_ エラー設計.md
メッセージ	../02_ 基本設計/06_ メッセージ一覧.md
認証・認可設計	../02_ 基本設計/08_ 認証・認可設計.md
詳細設計	../03_ 詳細設計/index.md

1.6 5. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
-	v1.0 リリース時点で全項目確定済み	低	確認済